

HORIZON MEDICAL — Cybersecurity Documentation

Documento: HM-CYB-001
Versión: 1.0
Fecha: 2026-05-16
Referencia: FDA Cybersecurity Guidance (2023), IEC 81001-5-1:2021, AAMI TIR57

Tabla de Contenidos

- 1. [Regulatory Context](#)
- 2. [Threat Modeling](#)
- 3. [Security Risk Assessment](#)
- 4. [Security Controls](#)
- 5. [Vulnerability Management](#)
- 6. [Software Bill of Materials \(SBOM\)](#)

1. Regulatory Context

1.1 Applicable Guidance and Standards

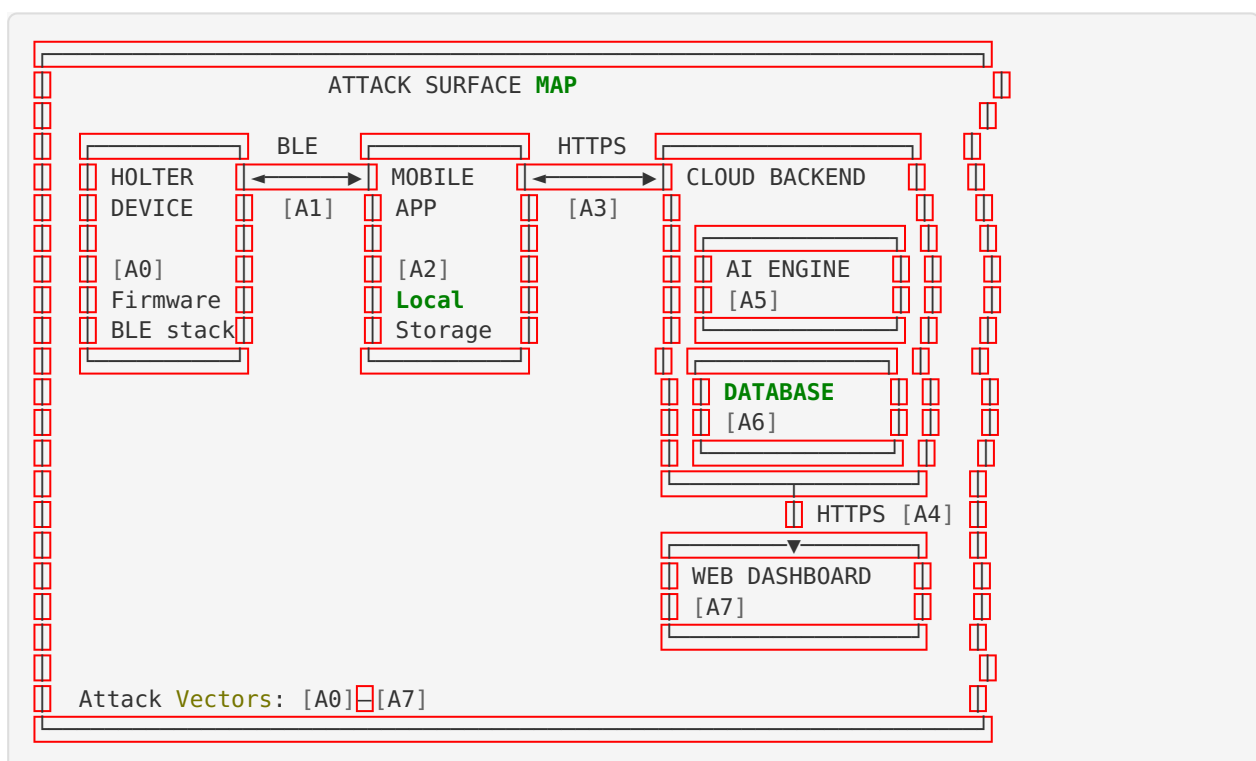
Document	Applicability
FDA: Cybersecurity in Medical Devices (2023)	Primary guidance for FDA 510(k) submission
IEC 81001-5-1:2021	Health software security — MDR harmonized standard
AAMI TIR57:2016	Principles for medical device security — Risk management
NIST Cybersecurity Framework (CSF) 2.0	Reference framework
HIPAA Security Rule	PHI protection (US market)
GDPR	Personal data protection (EU market)
Ley 1581 de 2012	Data protection (Colombia)

1.2 Device Cybersecurity Classification

Factor	Assessment
Connectivity	Yes — BLE + Internet (WiFi/cellular via smartphone) + Cloud
Data sensitivity	High — Protected Health Information (PHI)
Patient safety impact	Yes — delayed/incorrect arrhythmia detection could impact safety
FDA Tier	Tier 1 — Higher Cybersecurity Risk (can connect to another device/network AND could directly impact patient safety)

2. Threat Modeling

2.1 System Boundaries and Attack Surface



2.2 STRIDE Threat Analysis

ID	Component	Threat (STRIDE)	Description	Likelihood	Impact
T-01	[A1] BLE	Spoofing	Attacker impersonates the Holter device	Medium	High
T-02	[A1] BLE	Tampering	MITM attack modifies ECG data in transit	Low	Critical
T-03	[A1] BLE	Information Disclosure	Eavesdropping on BLE traffic captures ECG data	Medium	High
T-04	[A2] App	Tampering	Malware on phone accesses local ECG storage	Medium	High
T-05	[A2] App	Information Disclosure	Unencrypted local storage exposes patient data	Low	High
T-06	[A3] HTTPS	Spoofing	Fake server intercepts app traffic (MITM)	Low	Critical
T-07	[A3] HTTPS	Denial of Service	API endpoint flooded, preventing data upload	Medium	Medium
T-08	[A4] Dashboard	Spoofing	Stolen credentials access clinical dashboard	Medium	Critical
T-09	[A4] Dashboard	Elevation of Privilege	Non-admin user gains admin access	Low	Critical

ID	Component	Threat (STRIDE)	Description	Likelihood	Impact
T-10	[A5] AI Engine	Tampering	Adversarial inputs fool arrhythmia detector	Low	Critical
T-11	[A6] Database	Information Disclosure	Data breach exposes all patient records	Low	Critical
T-12	[A6] Database	Tampering	Unauthorized modification of clinical records	Low	Critical
T-13	[A0] Firmware	Tampering	Malicious firmware installed via compromised OTA	Low	Critical
T-14	[A0] Firmware	Denial of Service	Firmware crash causes device to stop recording	Low	High

3. Security Risk Assessment

3.1 Risk Evaluation (Pre-Mitigation)

Threat ID	CVSS Base Score	Exploitability	Impact	Risk Level
T-01	6.5	Medium	Confidentiality, Integrity	High
T-02	7.4	Low	Integrity (patient safety)	Critical
T-03	5.3	Medium	Confidentiality	Medium
T-06	7.4	Low	Integrity (patient safety)	Critical
T-08	8.1	Medium	Confidentiality, Integrity	Critical
T-10	6.8	Low	Integrity (patient safety)	High
T-11	9.1	Low	Confidentiality	Critical
T-13	8.6	Low	Integrity (patient safety)	Critical

3.2 Risk Evaluation (Post-Mitigation)

Threat ID	Controls	Residual CVSS	Residual Risk
T-01	BLE Secure Connections, device bonding	3.1	Low
T-02	AES-128-CCM encryption, integrity check	2.4	Low
T-03	BLE encryption (AES-128-CCM)	2.7	Low
T-06	TLS 1.3, certificate pinning	2.0	Low
T-08	MFA, session management, RBAC	3.5	Low
T-10	Input validation, confidence threshold	4.2	Medium (acceptable)
T-11	AES-256, RBAC, audit, backups, encryption	3.0	Low
T-13	Secure boot, signed OTA, dual-bank	2.5	Low

4. Security Controls

4.1 Security Architecture

Layer	Control	Implementation
Device (BLE)	Encryption	BLE Secure Connections (LE SC), AES-128-CCM
Device (BLE)	Authentication	Device bonding with passkey (6-digit)
Device (Firmware)	Integrity	Secure boot chain, signed firmware images
Device (OTA)	Update security	Dual-bank OTA, signature verification (ECDSA-P256), rollback protection
Transport (App→Backend)	Encryption	TLS 1.3 (minimum), strong cipher suites
Transport (App→Backend)	Certificate validation	Certificate pinning in mobile app
App (Local)	Data protection	AES-256 encrypted local database, keychain storage for credentials
App (Auth)	Authentication	Biometric + PIN authentication
Backend (API)	Authentication	OAuth 2.0 with JWT tokens, token expiration (1h access, 7d refresh)
Backend (API)	Authorization	Role-Based Access Control (RBAC): admin, clinician, patient
Backend (API)	Rate limiting	100 requests/minute per user, DDoS protection (WAF)
Backend (API)	Input validation	Schema validation, parameterized queries, sanitization
Backend (Storage)	Encryption at rest	AES-256 for database and file storage
Backend (Storage)	Access control	RBAC, principle of least privilege, MFA for admin
Backend (Logging)	Audit trail	

Layer	Control	Implementation
		Immutable audit logs for all data access, retention ≥6 years
Dashboard (Web)	Authentication	MFA (TOTP), session timeout (30 min), secure cookies
Dashboard (Web)	Protection	CSP, CORS, anti-CSRF tokens, XSS protection
AI Module	Input validation	Range checks, anomaly detection, signal quality assessment
AI Module	Model integrity	Checksum verification of model weights at startup

4.2 Cryptographic Standards

Function	Algorithm	Key Length	Standard
BLE encryption	AES-CCM	128-bit	Bluetooth Core Spec 5.0
Data in transit	TLS 1.3	256-bit (AES-256-GCM)	IETF RFC 8446
Data at rest	AES-GCM	256-bit	NIST SP 800-38D
Firmware signing	ECDSA	P-256 (256-bit)	FIPS 186-4
Password hashing	bcrypt	cost factor 12	OpenBSD
Token signing	RS256 (JWT)	2048-bit RSA	RFC 7519

--

5. Vulnerability Management

5.1 Vulnerability Monitoring

Activity	Frequency	Responsible
SBOM-based vulnerability scanning	Weekly (automated)	Security team
Penetration testing	Annually + after major releases	External security firm
Static code analysis (SAST)	Every commit (CI/CD)	Development team
Dynamic application security testing (DAST)	Monthly	Security team
Dependency vulnerability alerts	Continuous (Dependabot/Snyk)	Development team
CVE monitoring for SOUP components	Weekly	Security team

5.2 Patch Management Policy

Severity (CVSS)	Response Time	Patch Deployment
Critical (9.0–10.0)	24 hours assessment	72 hours
High (7.0–8.9)	48 hours assessment	2 weeks
Medium (4.0–6.9)	1 week assessment	Next planned release
Low (0.1–3.9)	2 weeks assessment	Future release

5.3 End-of-Life / End-of-Support Plan

Milestone	Action
End of support announcement	≥12 months before EOS
Last security patch	At EOS date
User notification	Recommend upgrade/replacement
Data migration	Tools provided for data export
Device decommissioning	Instructions for secure device wipe

6. Software Bill of Materials (SBOM)

6.1 SBOM Format

The SBOM is provided in **CycloneDX** format (JSON) and **SPDX** format, as recommended by FDA.

6.2 SBOM Summary

Firmware Components

Component	Version	License	Supplier	CPE
Zephyr RTOS	[Ver]	Apache 2.0	Zephyr Project	cpe: 2.3:o:zephyrproj ect:zephyr:*
Nordic nRF5 SDK	[Ver]	BSD-5-Clause	Nordic Semicon- ductor	N/A
mbled TLS	[Ver]	Apache 2.0	ARM	cpe: 2.3:a:arm:mbled _tls:*
CMSIS	[Ver]	Apache 2.0	ARM	N/A
ADS1298 Driver	[Ver]	Proprietary	Horizon Medical	N/A

Backend Components

Component	Version	License	Supplier	CPE
Node.js / Python	[Ver]	MIT / PSF	OpenJS / PSF	cpe: 2.3:a:nodejs:node.js:*
Express / FastAPI	[Ver]	MIT / MIT	Various	N/A
PostgreSQL	[Ver]	PostgreSQL	PostgreSQL Global	cpe: 2.3:a:postgresql:postgresql:*
Redis	[Ver]	BSD-3	Redis Ltd	cpe: 2.3:a:redis:redis:*
PyTorch / Tensor-Flow	[Ver]	BSD / Apache 2.0	Meta / Google	N/A
NumPy	[Ver]	BSD-3	NumPy	N/A
jsonwebtoken	[Ver]	MIT	Auth0	N/A
bcrypt	[Ver]	MIT	Various	N/A

Mobile App Components

Component	Version	License	Supplier
React Native	[Ver]	MIT	Meta
react-native-ble-plx	[Ver]	MIT	Polidea
react-native-encrypted-storage	[Ver]	MIT	Various
axios	[Ver]	MIT	Various

Dashboard Components

Component	Version	License	Supplier
React.js	[Ver]	MIT	Meta
Chart.js	[Ver]	MIT	Chart.js
Material UI	[Ver]	MIT	MUI

6.3 Known Vulnerabilities

Component	CVE	CVSS	Status	Mitigation
[To be populated from vulnerability scan]	—	—	—	—

Note: Full SBOM in machine-readable format (CycloneDX JSON) is provided as a separate file:
SBOM-Horizon-Medical-v1.0.json

Appendix: Penetration Testing Summary

Test Area	Methodology	Finding Summary	Status
BLE Communication	Bluetooth sniffing, MITM attempt	[Results]	[Remediated/Accepted]
Mobile App	OWASP MASTG, static/dynamic analysis	[Results]	[Remediated/Accepted]
Backend API	OWASP Top 10, fuzzing, auth testing	[Results]	[Remediated/Accepted]
Dashboard Web	OWASP Top 10, XSS, CSRF, injection	[Results]	[Remediated/Accepted]
Cloud Infrastructure	Cloud security review, config audit	[Results]	[Remediated/Accepted]

Control de Versiones:

Versión	Fecha	Autor	Descripción
1.0	2026-05-16	Security Engineering	Creación inicial